Case study

Page No.
Date 27 8 26

Case study :-

1. Bright mart is an medium sized online shopping company. Customers use its website or mobile application to purchase products.

The company stores
1. Customers name
2. Email address
3. phone number
4. delivery addresses
5. passwords
6. Order info
7. payment - related info

Bright mart has around 100 employees. The company recently hired several new employees. To make things easier the IT Department gave employee access to different internal systems.

However the company has the following security weaknesses

Some employees use simple passwords such as Brightmart123

Many employees use same passwords for multiple systems.

- Software updates are sometimes delayed
- The company does not regularly conduct employee cyber security training
- There is no multi-factor authentication for some Imp accounts
- Employee can access sensitive information that they do neeelsarily need for their jobs.
- Backups are performed only a month.

The Incident
One monday morning, an employee named Rahul receives an Email

Subject - Urgent - your account will be suspended

The Email appears to come from Company IT Department
It says!
"Your Company account will be suspended today Click the link below & verify your password Immediately

Stage 4: Business Impact
Brightmart New Faces several problems
Financial Impact
The company loses sales because it is website is unavailable.

Data Impact
Customer Info may have been stolen,
operational Impact Employees cannot access Important System.

Reputation Impact :-
Customer lose confidence in the Company legal / compliance Impact -
The company may face regulatory or legal consequences depending on what Information was exposed & which laws.

-) Group 1 - Identify the threats
what threats are present in the case?

-) Group 2 - Identify the vulnerabilities
what weakness is Brightmart security allowed the attacker to suceed?

-) Group 3 - Apply to CIA traid
was confidential info exposed?
was info chaged or damaged?
were System available to legitimate user?

Date

Questions: which vulnerability allowed the attacker to move further into the organisation?

Stage 3: Ransomware

Two days later employee arrives at work & discover that they cannot access, important files, a message appears on computer.

"Your files have been encrypted. pay the ransom to recover".

The company's customer database & several imp business files are encrypted

unfortunately, the company most recent back up is almost a month old.

Brightmarks website stop working. Customers cannot place order The customers support term cannot access customer records.

Page No.
Date

Rahul clicks the link
The page looks identical to company page.

Stage1: unauthorized access

The attacker user Rahul's credentials to access Brightmart internal system.
Because Rahul uses the same password for another systems, the attacker is also able to access that systems

The attackers discover that Rahul has access to customer information
The attacker downloads a large amount.

Stage 2: Malware Attack
The attacker sends another email to Rahul containing a malevous attachmens Rahul opens the attachmens
Malware is installed on his computer.

The malware begin communicating with the attacker's system.

The attackers now attempts to move from Rahul's computer to other system within Brightmart's network.

5. Was Credential info exposed?
Yes [customer changed or damaged?]

Was information changed or damaged
Yes (potentially) [The attacker could modify or encrypt files]

Were system available to legitimate users?
NO [The web & internal system become available beause OR Ransomware?

6. What should Brightmart do to prevent this from happening again?

- Use strong password
- Implement Multi-Factor authentication (MFA)
- Provide regular cybersecurity awareness
- Conduct phising awareness exercises
- Keep software updated
- Follow the principle OR least privilege
- Segment Important Networks.
- Maintain regular backup
- Encrypt sensitive data
- Deploy antivirus protection.

Page No.
Date

3. What threats are present in case?
- phishing
- Malware
- Ransomware
- Credential theft
- Unauthorized access
- Data theft.

4. Which weakness in Brightmart Security allowed the attack to succeed

Vulnerability - How it helped the attacker,
Weak passwords - Easier to compromise account
password reuse - one stolen password gives access to multiple system

No MFA - Stolen password maybe enough to login it

lack of training - Employee falls for phishing

Delayed update - vulnerable software may be exploited

Excessive privileges - Attackers can access more data

Infrequent backup difficult to recover after ransomware

Page No.
Date

- Group 4 - Security Solutions
Who is responsible for Cybersecurity?
Was phising the only problem??
What was the biggest vulnerabilities?

Solution :- Case Study.

1. What Cybersecurity problem has occured?

Possible answer -
- phising
- Credential theft
- unauthorized acess
- Data breach.

2. which vulnerability allowed the attacker to move further into the organisation?

- weak passwords
- Excessive user privilege
- lack OR MFA
- poor network security
- lack of employee awareness
- outdated Software.

Page No.
Date

7. Who is responsible for cybersecurity?

Not only IT, department every employee uses the org. system has a role in cybersecurity.

8. was phising the only problem?

-> No, phising was the intial attack but weakness such as passwords reuse lack of MFA ensure privilege poor backups insufficient training allowed the attack to become much more damaging.

9. What was the vulnerability?

-i) lack to employee awarness was a major vulnerability because attack stored when Rahul clicked.

2. poor backup practices were the biggest problem because Brightmart couldn't recover the ransomware

Quick Assement.

1. what was the intial attack against Brightmart?

2. Give three vulnerabilities that helped the attackers.

3. Which three security principle of CIA Triad were affected?

4. What was the Impact of ransomware on Brightmart.

5. Suggest three security controls Brightmart should implement.

Answers:

1. The initial attack against Brightmart was phishing.

2. a) password reuse
b) poor backups
c) Delayed software updated.

3. All the principles were affected.

4. The ransomware demanded for money for the files to backup

5. a) Brightmart should take cyber security training
b) Improvement of employee awareness
c) Software should be updated monthly by the IT department

d) Employees should know about phising.

* Attackers exploit the system Network & human pshycology

1. Dos & DDos (Denial - of - Services) overwhelming a target server with massive traffic from compromised system until legitimate user cannot access the website.

2. Man - in - the middle (html) positioning secretly between comunica ting parties to intrecept or manupulate

3. Social engineering & Phishing Bypassing technical defenses entirely by exploiting human trust fear or urgency to steal password

* phases of hacking

1. Foot printing - collection of info of victim as much as possible

2. Scanning - checking whether info collected is right or wrong

3. Gaining access - To Gaining access to victims computer or system.